

SOC

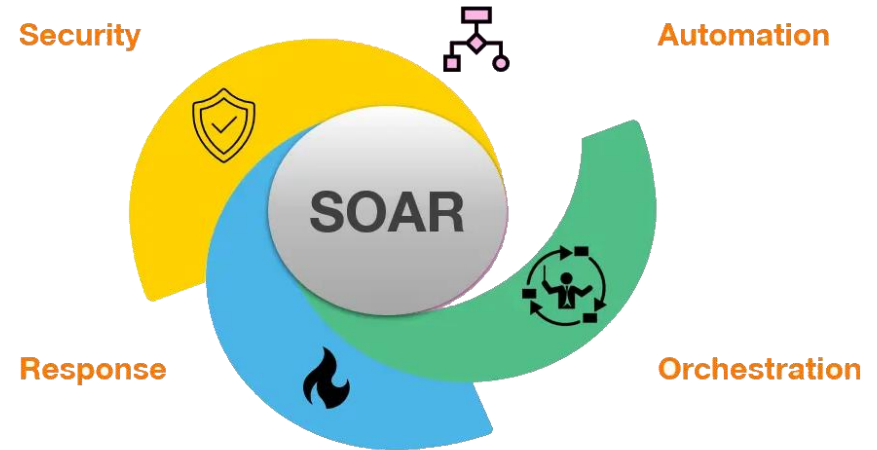
Automation & Orchestration

Modul SOC.F2601



Programm

- Recap SIEM
- Automatisierung und Orchestrierung
- SIEM vs. SOAR
- SOAR Use Cases
- Automatisierung Beispiele
- OSINT
- Produkte





Recap - SIEM

Security Information Event Management (SIEM) ist eine Technologie, die in Unternehmen eingesetzt wird, um Echtzeitberichte und Langzeitanalysen von Sicherheitsereignissen zu erstellen.

SIEM-Systeme umfassen im Wesentlichen die folgenden Funktionen:

- **Forensische Analyse** - Die Fähigkeit, Protokolle und Ereignisaufzeichnungen von Quellen zu durchsuchen und vollständige Informationen für die forensische Analyse bereitzustellen.
- **Korrelation** - Untersucht und vergleicht Protokolle und Ereignisse von verschiedenen Systemen oder Anwendungen und beschleunigt so die Erkennung von und Reaktion auf Sicherheitsbedrohungen.
- **Aggregation** - Reduziert das Volumen der Ereignisdaten durch Konsolidierung doppelter Ereignisaufzeichnungen.
- **Reporting** - Stellt die korrelierten und aggregierten Ereignisdaten in Echtzeitüberwachung und Langzeitzusammenfassungen dar.

Automatisierung / Orchestrierung

- Bei der Sicherheitsautomatisierung geht es darum, den Sicherheitsbetrieb einfacher und effizienter zu gestalten, während die Sicherheitsorchestrierung verschiedenen Security-Tools miteinander verbindet, damit sie ineinandergreifen und verzahnt arbeiten.
- Die Begriffe Sicherheitsautomatisierung und Sicherheitsorchestrierung werden häufig synonym verwendet, doch die beiden Plattformen haben in Wirklichkeit sehr unterschiedliche Funktionen.
 - Unter anderem verkürzt die Sicherheitsautomatisierung die Zeit, die für die Erkennung und Reaktion auf sich wiederholende Incidents und "*false positive*"-Meldungen nötig ist, so dass Warnmeldungen nicht zu lange unbehandelt bleiben. Ausserdem nimmt sie Sicherheitsanalysten monotone Arbeiten ab, so dass diese sich auf strategische Aufgaben wie investigative Recherchen konzentrieren können.
 - Die Sicherheitsautomatisierung unterliegt dabei jedoch gewissen Einschränkungen, da jedes Playbook ein bekanntes Szenario mit einer vorgeschriebenen Vorgehensweise behandelt.

Orchestrierung

- Die Sicherheitsorchestrierung erleichtert dagegen den einfachen Informationsaustausch und ermöglicht mehreren Tools, als Gruppe auf Incidents zu reagieren, selbst wenn die Daten über ein grosses Netzwerk und mehrere Systeme oder Geräte verteilt sind.
- Die Sicherheitsorchestrierung nutzt mehrere automatisierte Aufgaben, um einen vollständigen, komplexen Prozess oder Workflow auszuführen.
- Bei der Sicherheitsautomatisierung geht es um eine Reihe von Einzelaufgaben geht, während die Sicherheitsorchestrierung den Prozess von Anfang bis Ende verzahnt und beschleunigt.

→ Die beiden Ansätze werden am besten zusammen eingesetzt – mit dieser Kombination können Security-Teams ihre Effizienz und Produktivität maximieren.

SIEM vs. SOAR

SIEM liefert Details zur Quelle der verdächtigen Aktivität:

- Benutzerinformationen wie Benutzername, Authentifizierungsstatus, Standort.
- Geräteinformationen wie Hersteller, Modell, Betriebssystemversion, MAC-Adresse, Netzwerkverbindungsmethode und Standort.
- Haltungsinformationen wie die Konformität des Geräts mit der Sicherheitsrichtlinie und aktualisierte Antiviren-Dateien und OS-Patches.

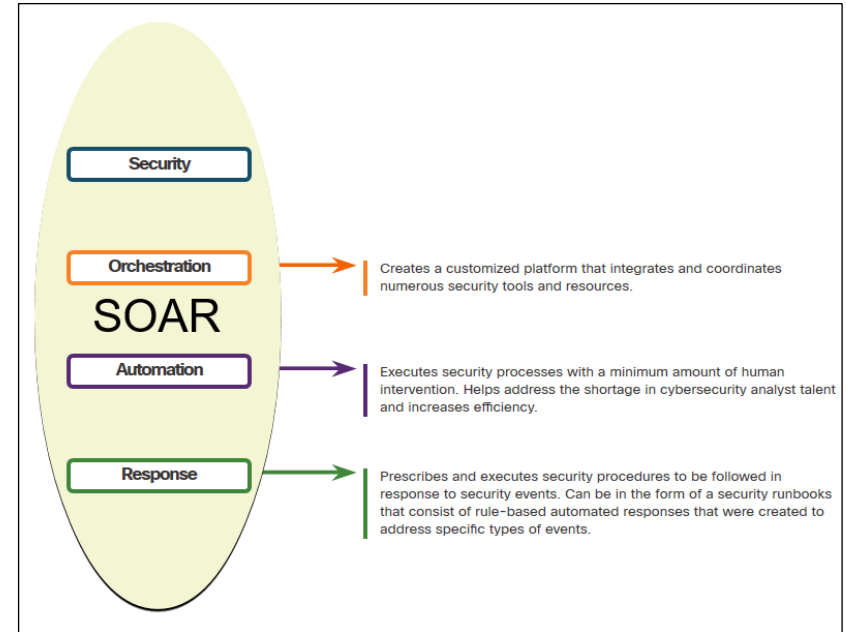
SOAR

- Security Orchestration, Automation, and Response (SOAR) erweitert SIEM.
- SOAR unterstützt Sicherheitsteams bei der Untersuchung von Sicherheitsvorfällen und bietet eine erweiterte Datenerfassung sowie eine Reihe von Funktionen, die bei der Reaktion auf Sicherheitsvorfälle helfen.

SOAR



SOAR-Systeme integrieren Threat Intelligence und automatisieren Arbeitsabläufe einerseits zur Incident-Untersuchung und andererseits auch für Incident-Response auf Basis der vom Sicherheitsteam entwickelten Playbooks.

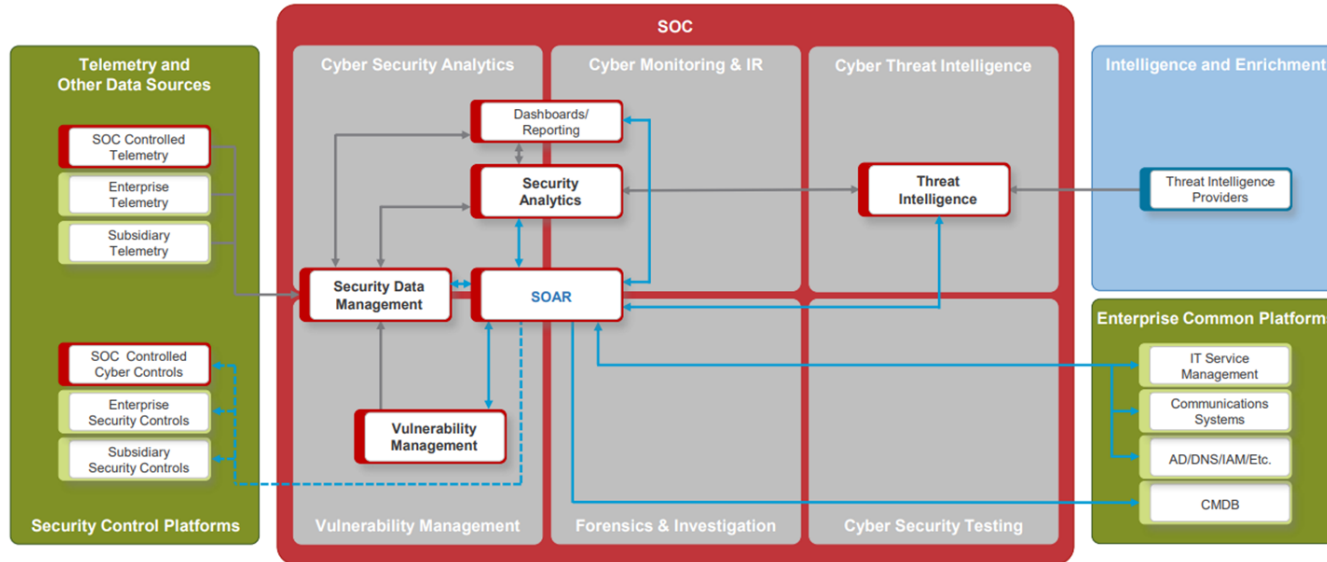


SOAR



- Bietet Fallmanagement-Tools welche dem Cybersecurity-Personal ermöglicht, Vorfälle zu recherchieren und zu untersuchen, beispielsweise durch Integration von **Threat Intelligence** in die Sicherheitsplattform.
 - Verwendung von künstlicher Intelligenz die bei der Erkennung, der Analyse und Reaktion auf Vorfälle hilft.
 - Automatisierung komplexer Incident Response-Prozessen bei denen es sich um potenziell arbeitsintensive Aufgaben handelt, die sonst von Mitarbeitern des SOC durch die Ausführung von Playbooks durchgeführt werden müssen.
 - SOAR-Technologie bietet Dashboards und Berichte zur Dokumentation der Incident Response, um die Leistungskennzahlen des SOC zu verbessern und um somit die Sicherheit des Unternehmens zu erhöhen.
- SOAR unterstützt Analysten dabei, schneller auf Cyberbedrohungen zu reagieren.

SOAR – Einbettung ins SOC



Use-Cases für SOAR

- Bevor man sich Gedanken macht über die Beschaffung einer SOAR-Plattform sollten man sich unbedingt überlegen, wie die Unternehmung eine solche Lösung nutzen wird.
- Use Cases sollten die grössten "Pain Points" widerspiegeln und aufzeigen, wie man von der Technologie maximal profitieren kann.
- Typische Anwendungsbeispiele sind teilweise stark branchenabhängig es gibt aber auch einige Beispiel unabhängig von den Branchen:
 - Massen-Phishing Mails
 - Malware (z.B. durch infizierte Werbung) auf News Sites
 - ...

SOAR Use-Case 1

Unterstützung von Penetrationstests

- Fast 40 % der Unternehmen führen Penetrationstests nur unregelmässig oder gar nicht durch*.
 - Mit SOAR-Plattformen können Aktivitäten wie Asset-Erkennung, Klassifizierung und Zielpriorisierung automatisiert werden.
- Dies gibt den Security-Teams die Möglichkeit, Penetrationstests zu operationalisieren.

*Aus einer 2019 durchgeführten Umfrage von eSecurity Planets zum Status der IT-Sicherheit (<https://www.esecurityplanet.com/threats/a-third-of-companies-are-largely-unprepared-for-cybersecurity-attacks-esecurity-planet-survey/>)

SOAR Use-Case 2

Bedrohungssuche – Threat Hunting

- Da sich Security-Teams tagtäglich stundenlang mit einer Flut von Warnmeldungen befassen bleibt meist keine Zeit für die Suche nach Bedrohungen. Deren Untersuchung kann Einfluss auf die strategische Planung und somit langfristig zu Verbesserungen der Sicherheit führen.
- Automatisierungslösungen wehren viele der aufgetretenen bösartigen Bedrohungen sofort ab, so dass Sicherheitsteams Zeit haben, sich Projekten zur Verbesserung der allgemeinen Sicherheit im gesamten Netzwerk/IT Infrastruktur zuzuwenden.
- Aus der Finanzbranche* wird beispielsweise berichtet, dass jedes einzelne Unternehmen etwa 2.000 Angriffe pro Minute verzeichnet und sich die Zahl der Sicherheitsverletzungen und Diebstähle sensibler Daten in der letzten fünf Jahren verdreifacht hat.
- Mithilfe von Automatisierung könnten viele dieser Angriffe sofort abgewehrt werden, was wiederum Sicherheitsanalysten die notwendige Zeit gibt, Schwachstellen zu schliessen und Hackern den Zugriff auf vertrauliche Informationen erschwert.

(*Quelle: <https://www.forbes.com/sites/bhaktimirchandani/2018/08/28/laughing-all-the-way-to-the-bank-cybercriminals-targeting-us-financial-institutions/#5b8081106e90>)

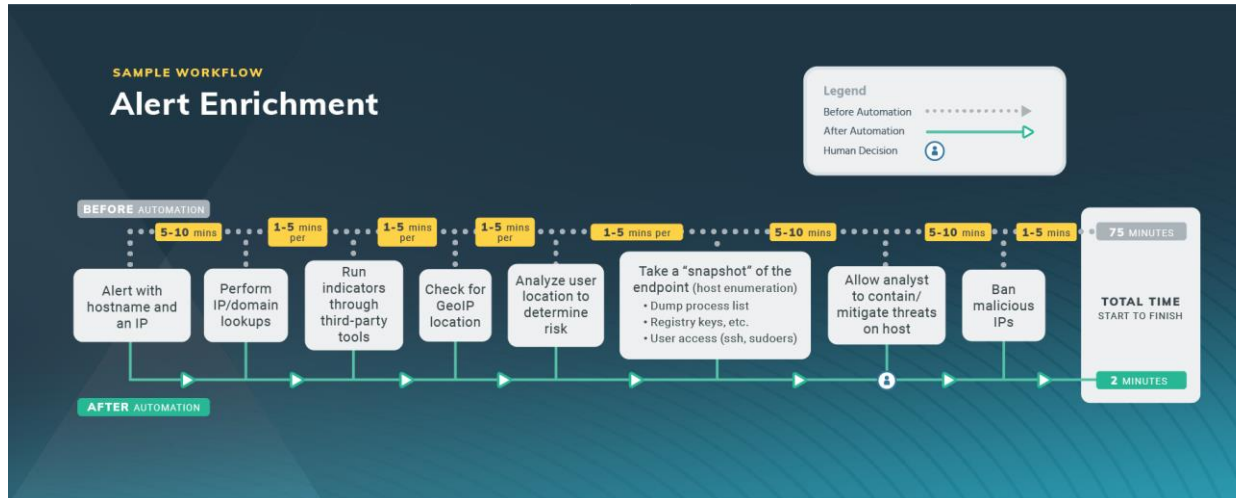
SOAR Use-Case 3

Abwehr von Cyberangriffen / Automatic Incident Response

- Art und Ausprägung von Security-Incidents können variieren und manche Branchen sind stärker betroffen als andere. Während beispielsweise Phishing-Angriffe ganz allgemein zunehmen, stieg die Anzahl solcher Attacken auf spezielle Branchen sprunghaft an:
 - Gesundheitswesen – hier lag der Hauptzweck der Angriffe darin, Anmeldeinformationen für den Zugriff auf Krankenhausdatenbanken zu stehlen. (<https://healthitsecurity.com/news/credential-compromise-top-goal-of-phishing-attacks-in-2018>)
 - Der Einzelhandel kämpft dagegen mit Malware-, SPAM- und Phishing-Angriffen in bisher unerreichtem Mass. (<https://chainstoreage.com/top-cio-cybersecurity-concerns-are>)
 - In der Industrie ist zu beobachten, dass immer häufiger Schwachstellen bei Steuerungsnetzwerken in Fabrikhallen von Hackern ausgenutzt werden. (<https://www.industryweek.com/technology-and-iiot/information-technology/article/21987614/cyberthreats-targeting-the-factory-floor>)
- SOAR-Plattformen können den Ursprung solcher Angriffe automatisch aufdecken und untersuchen. Sie könnten zum Beispiel eine verdächtige Phishing-E-Mail erkennen und verfolgen, im Netzwerk nach weiteren Kopien der E-Mail suchen und diese isolieren oder löschen sowie IP-Adressen und URLs blockieren, um zu verhindern, dass diese bösartigen E-Mails den Posteingang einer anderen Person erreichen.
- Darüber hinaus könnten sie Bedrohungen eindämmen, bevor vertrauliche Daten an Angreifer weitergegeben werden, und damit die Reaktionszeiten von Stunden auf Minuten verkürzen.

Automation-Beispiel 1: Alert Enrichment

- Automatisches anreichern der Sicherheitswarnungen mit wichtigen Informationen wie z. B. geo-IP-Lookups, Domain-Analysen, Malware-Detonation und mehr. Orchestrierung der bevorzugten Threat-Intelligence-Plattformen oder Verwendung einer Vielzahl kostenloser und Open-Source-Tools, um sicherzustellen, dass das Security-Team mit dem Kontext ausgestattet ist, den es braucht, um Massnahmen zu ergreifen. So hat es mehr Zeit und mehr Kontext, um gegen tatsächliche Bedrohungen vorzugehen.



Automation-Beispiel 1: Network Enrichment

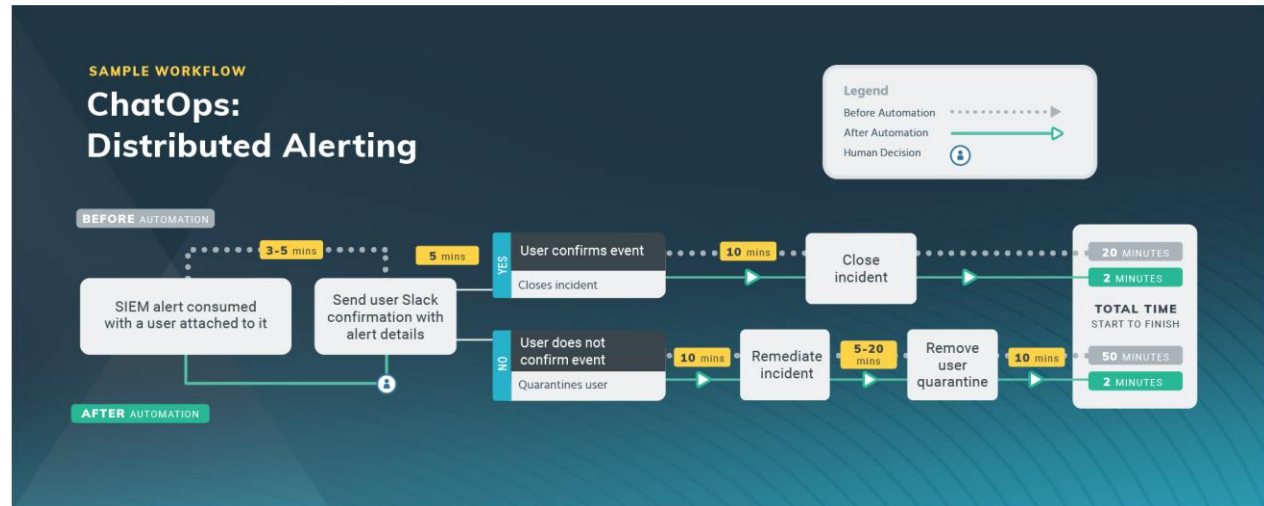
- Am Beispiel von Splunk Phantom



Quelle: <https://splunk.com>

Automation Beispiel 2: Distributed Alerting and Custom Escalation Pathways

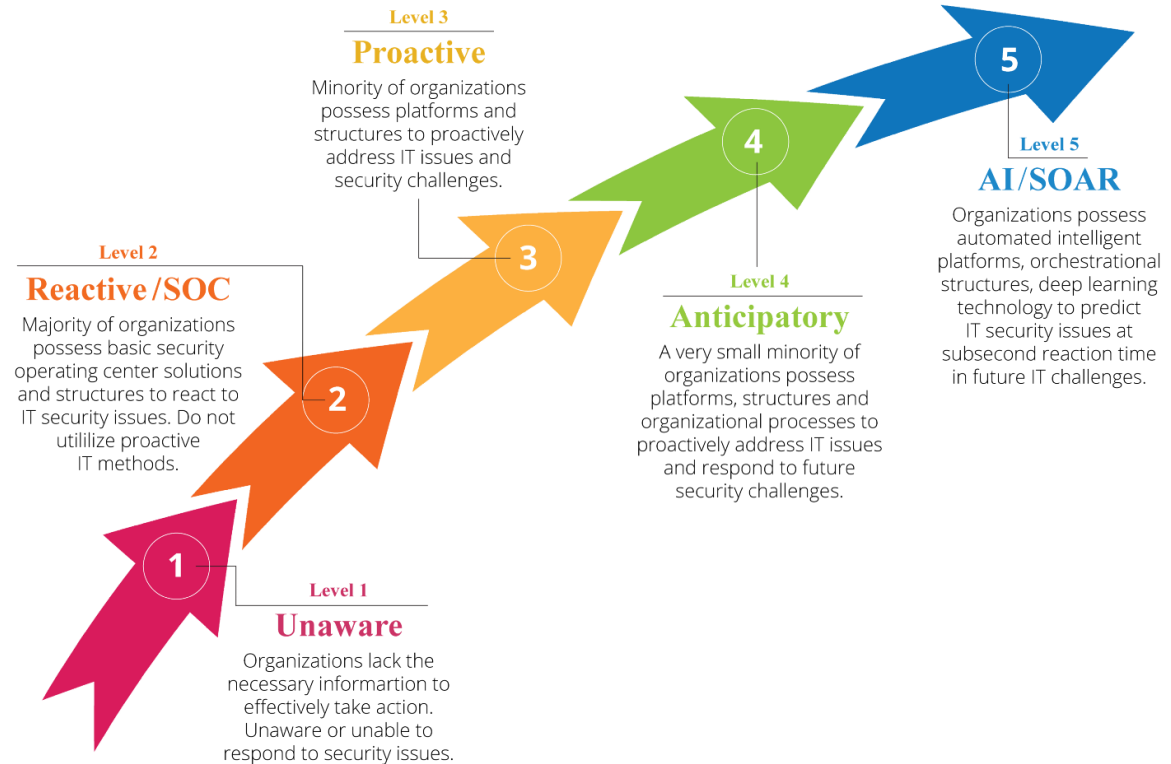
- Verteiltes Alerting rationalisiert die Geschäftsabläufe, was zu mehr Zusammenarbeit und Effizienz führt. Man kann zum Beispiel Aktionen auslösen, um Alarme, Incident-Notifications, Kommentare und andere Daten an Lösungen wie JIRA oder Slack zu senden. Die Automatisierung kann auch Warnungen, die von anderen Sicherheitstools eingehen, direkt an Ihre Chat-Anwendungen weiterleiten sowie Aufgaben an andere verbundene Tools zurückdelegieren.



SOAR-Adoption

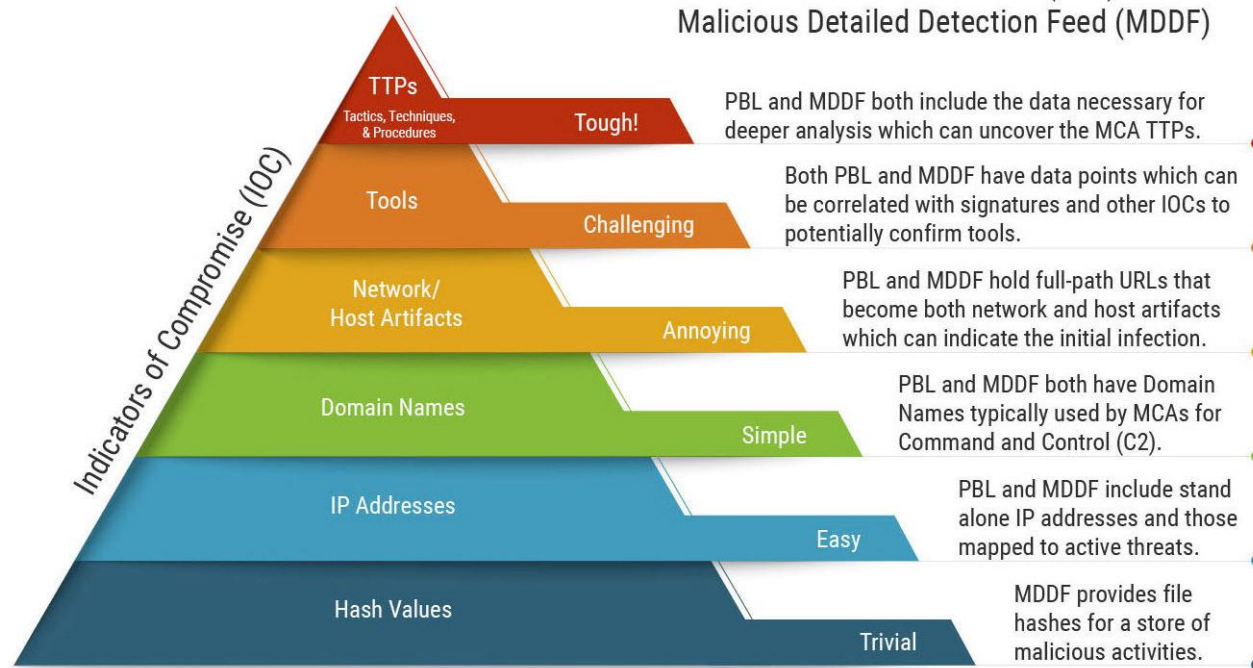
"Gartner predicts that by year-end 2022, 30% of organizations with a security team larger than five people will leverage SOAR tools in their security operations, up from less than 5% today."

Gartner Market Guide for Security Orchestration, Automation and Response Solutions, 2019



"Pyramid of Pain"

CTI: PhishBlockList (PBL) and Malicious Detailed Detection Feed (MDDF)



The Pyramid of Pain



Open Source Intelligence - OSINT

Open Source Intelligence (OSINT) ist ein Begriff aus der Welt der Nachrichtendienste und des Militärischen Nachrichtenwesens. Es handelt sich um einen Begriff, der ursprünglich von Nachrichtendiensten geprägt wurde.

- OSINT wird genutzt, um frei verfügbare Informationen aus öffentlichen Quellen wie dem Internet zu beschaffen, zu sammeln, zu analysieren und zusammenzuführen.
- OSINT wird genutzt, um sich ein besseres Bild der Bedrohungslandschaft zu machen und Unternehmen sowie Benutzern zu helfen, sich vor bekannten Risiken in ihren IT-Umgebungen zu schützen.
- Weitere OSINT-Anwendungsszenarien in der Cybersicherheit umfassen die Suche nach Schwachstellen in der IT-Infrastruktur, die Identifikation von Bedrohungen und die Überwachung von Social-Media-Plattformen.
- OSINT kann dem SOC-Team helfen weitere Informationen zu den aufgezeichneten Daten zu liefern!

- [illegible]

Informationsgewinnung aus technischer Sicht

- IP-Adressen
- Geo-Location
- WHOIS-Einträge
- DNS-Einträge
- Banner Grabbing
- Shodan DB Requests
- ...

The screenshot displays the Shodan search engine interface. At the top, the search bar contains 'cisco configuration'. Below the search bar, there are navigation tabs: Exploits, Maps, Share Search, Download Results, and Create Report. The main content area is divided into several sections:

- TOTAL RESULTS:** 13,588
- TOP COUNTRIES:** A world map showing the distribution of results by country. The top countries listed are: United States (1,534), China (1,292), Argentina (916), India (760), and United Kingdom (592).
- TOP SERVICES:** A list of services and their counts: Telnet (11,564), 2002 (1,412), 4002 (124), 9002 (100), and X Windows (6001) (86).
- TOP ORGANIZATIONS:** A list of organizations and their counts: Telecom Argentina S.A. (587), Comcast Business (425), Eclipse Internet (406), CAT Telecom (403), and Telecom Personal (165).
- TOP PRODUCTS:** A list of products and their counts: Cisco SPA112 VoIP adapter http config (5), TANDBERG/529 (ce9.3.2.748b9742af6) Cisco... (1), TANDBERG/528 (TC7.3.8.8b95796) Cisco... (1), TANDBERG/528 (TC7.3.17.52b35e9) Cisco... (1), and DD-WRT milli_httpd (1).

On the right side, there are detailed results for specific IP addresses:

- 106.39.102.147:** China Telecom Beijing. Added on 2019-12-04 20:31:50 GMT. Location: China, Beijing. Description: Cisco Configuration Professional (Cisco CP) is installed on this device. This feature requires the one-time use of the username "cisco" with the password "cisco". These default credentials have a privilege level of 15...
- 181.10.207.9:** host19.181-10-207.telecom.net.ar. Added on 2019-12-04 20:27:27 GMT. Location: Argentina, Corrientes. Description: Cisco Configuration Professional (Cisco CP) is installed on this device. This feature requires the one-time use of the username "cisco" with the password "cisco". These default credentials have a privilege level of 15...
- 79.129.55.236:** oizh5g.static.otenet.gr. Added on 2019-12-04 20:26:40 GMT. Location: Greece, Athens. Description: Cisco Configuration Professional (Cisco CP) is installed on this device. This feature requires the one-time use of the username "cisco" with the password "cisco". These default credentials have a privilege level of 15...
- 203.90.65.169:** Tikona Infinet. Added on 2019-12-04 20:29:29 GMT. Location: India. Description: Cisco Configuration Professional (Cisco CP) is installed on this device. This feature requires the one-time use of the username "cisco" with the password "cisco". These default credentials have a privilege level of 15...
- 181.13.19.225:** host225.181-13-19.telecom.net.ar. Added on 2019-12-04 20:28:40 GMT. Location: Argentina, Buenos Aires. Description: Cisco Configuration Professional (Cisco CP) is installed on this device. This feature requires the one-time use of the username "cisco" with the password "cisco". These default credentials have a privilege level of 15...

Hilfreiche Metadaten

- Software: Produkt, Versionsnummer, installierte Module, ...
- Zeit / Zeitzone des Zielsystems
- eMail-Adressen
- ...

The screenshot displays the Shodan search engine interface. At the top, the search bar contains the query 'php <7.3'. Below the search bar, there are tabs for 'Exploits' and 'Maps'. The main content area is divided into several sections:

- TOTAL RESULTS**: 457
- TOP COUNTRIES**: A world map showing the distribution of results by country. The United States has the highest count at 148, followed by France (39), Japan (34), Singapore (28), and Ireland (27).
- TOP SERVICES**: A list of services found, including HTTPS (28), HTTP (14), Pipeline Pilot (5), 16992 (4), and Andromouse (3).
- TOP ORGANIZATIONS**: A list of organizations, including Amazon.com (196), Amazon Data Services France (26), Amazon Data Services UK (15), Amazon Data Services Ireland Limited (14), and Amazon Corporate Services Pty (13).
- TOP OPERATING SYSTEMS**: A list of operating systems, including Linux (1) and Linux 3.x (1).

On the right side, there are three detailed search results for specific IP addresses:

- 3.93.34.133**: ec2-3-93-34-133.compute-1.amazonaws.com. Added on 2019-12-04 16:49:08 GMT. Location: United States, Ashburn. HTTP/1.1 200 OK. Date: Wed, 04 Dec 2019 16:49:08 GMT. X-Powered-By: PHP/5.6.20-0+deb8u1. Server: SentinelProtectionServer/7.3. Content-Length: 83. Content-Type: text/html.
- 18.136.144.210**: ec2-18-136-144-210.ap-southeast-1.compute.amazonaws.com. Added on 2019-12-04 18:42:34 GMT. Location: Singapore, Singapore. HTTP/1.1 404 Not Found. Server: nginx/1.14.2. Content-Type: text/html; charset=UTF-8. Transfer-Encoding: chunked. Connection: keep-alive. X-Powered-By: PHP/7.2.13. Cache-Control: no-cache, private. Date: Wed, 04 Dec 2019 18:42:34 GMT. 5253. <!DOCTYPE html>. <html>. <head>. <meta name="...>.
- 13.235.73.174**: ec2-13-235-73-174.ap-south-1.compute.amazonaws.com. Added on 2019-12-04 19:31:36 GMT. Location: India, Mumbai. HTTP/1.1 200 OK. Date: Wed, 04 Dec 2019 19:17:14 GMT. X-Powered-By: PHP/5.3.6-13ubuntu3.6. Server: SentinelProtectionServer/7.3. Content-Length: 83. Content-Type: text/html.

Ziele von OSINT – Gegenüberstellung

- Read Team: **offensive Ziele**

- Blue Team: **defensive Ziele**

Social Engineering

- a. Gefundene Schlüsselpersonen gezielt angreifen.
- b. Awareness Training mit identifizierten Schlüsselpersonen durchführen.

Denial of Service

- a. Gefundene Systeme angreifen.
- b. DoS-Resistance prüfen und erhöhen.

Password brute force attacks

- a. Offene IAM Systeme angreifen.
- b. Brute-Force-Angriffen unterbinden (beispielsweise mittels MFA).

Target infiltration

- a. Gefundene Lücken in Systemen ausnutzen.
- b. Identifizierte Lücken schliessen.

User accounts take over

- a. Gefundene Benutzeraccounts gezielt angreifen über
 - i. Social Engineering oder Anhand von «leaked credentials» oder Password Brute-Force-Angriffen.
- b. Überprüfung von öffentlichen Benutzeraccounts und absichern mittels
 - i. MFA oder Automatisierten «leaked credentials»-Checks oder Unterbindung von Brute-Force-Angriffen.

Identity theft

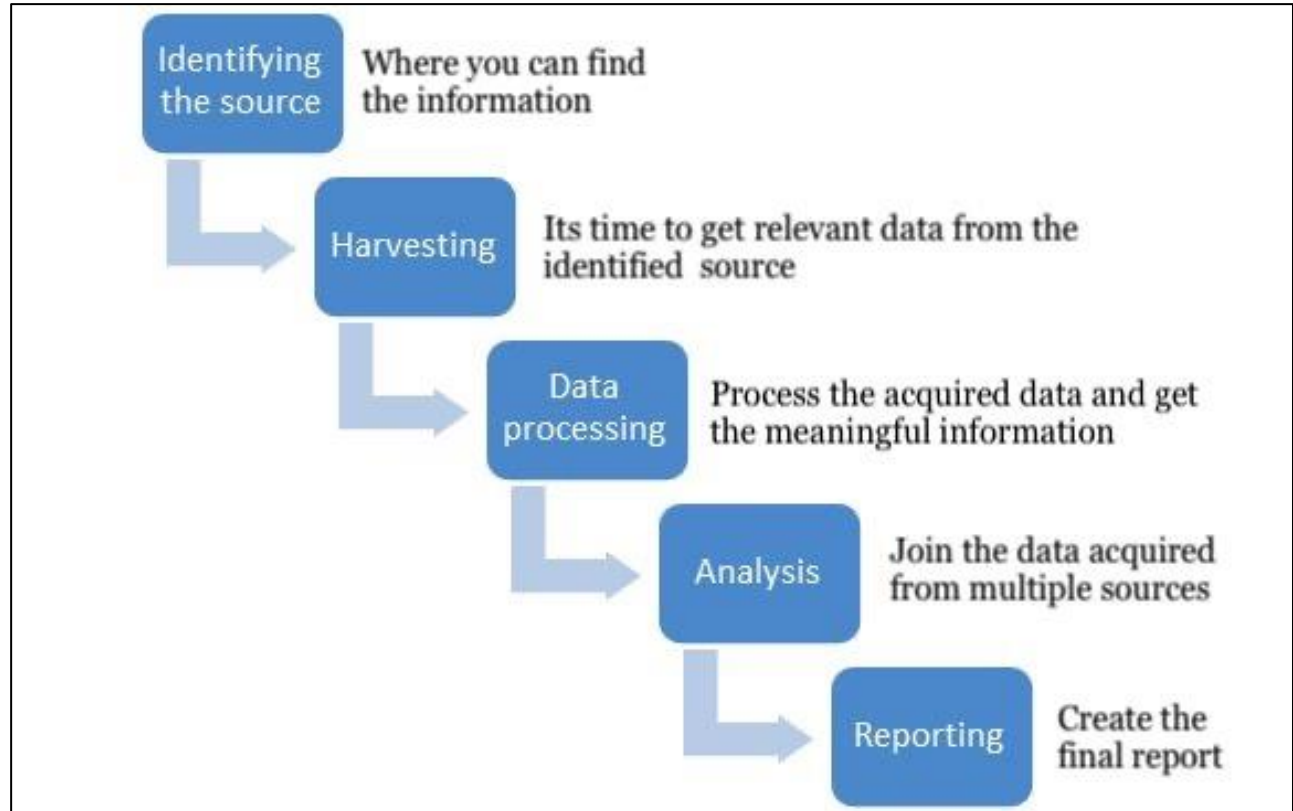
- a. Sich als andere Person ausgeben (z.B. am Servicedesk), um Zugriff zu erhalten.
- b. Personalschulung und Erhöhung der Awareness indem
 - i. Sicherheitsfragen gestellt werden und eine unautorisierten Password-Resets durchgeführt werden.

Data theft

- a. Daten von offenen Systemen (Web, FTP, S3-Buckets, ...) beziehen.
- b. Offene Systeme absichern.

Quelle: Termpaper Schafer, Inäbnit

OSINT Prozess



OSINT Suchmaschinen

- Google - <https://google.com>
- Shodan - <https://shodan.io>
- Censys - <https://censys.io>
- Fofa - <https://en.fofa.info>
- Dogpile - <http://www.dogpile.com>
- Archives - <https://archive.org>

OSINT – Ressourcen und Tools (1)

DNS / Subdomain Enumeration:

- Die Aufzählung von Subdomains ist der Prozess der Suche nach gültigen (auflösbaren) Subdomains für eine oder mehrere Domänen.
- Eine ungesicherte Subdomain kann zu einem ernsthaften Risiko für Ihr Unternehmen führen.
- Tools für die Subdomainaufzählung:
 - Aquatone - <https://github.com/michenriksen/aquatone>
 - Sublister - <https://github.com/aboul3la/Sublist3r>
 - DNS dumpster - <https://dnsdumpster.com>
 - Facebook - <https://developers.facebook.com/tools/ct>

OSINT – Ressourcen und Tools (2)

E-Mail Harvesting:

- Das Sammeln von E-Mail-Adressen ist eine OSINT-Technik, die Angreifern mehr Informationen liefert um Angriffe wie das Ausfüllen von Passwörtern und Social Engineering-Angriffe durchzuführen.
- The Harvester
<https://github.com/laramies/theHarvester>
- Prowl
<https://github.com/nettitude/prowl>
- Have I been pwned
<https://haveibeenpwned.com>

SOAR-Produkte

- Splunk: SOAR
https://www.splunk.com/en_us/products/splunk-security-orchestration-and-automation.html
https://www.youtube.com/watch?v=Jynck9Yw_dg
- Rapid7: SIEM
<https://www.rapid7.com/de/products/siem/>
- IBM: Qradar SOAR
<https://www.ibm.com/products/qradar-soar>
- Cyware:
<https://www.cyware.com/platform/security-orchestration-automation>
- Microsoft: Sentinel
<https://www.microsoft.com/de-de/security/business/siem-and-xdr/microsoft-sentinel#Capabilities>